HANDOUT

Day 4: where this lives in the real world

For each idea from today, the real rule, standard or kind of tool, and the question to ask. Named products are examples of a category, not recommendations. Dates and scope are illustrative: confirm them with CSOB compliance.

Today's idea	Real-world examples	Question to ask
Which rule does this touch?	GDPR (lawful basis, transparency, processors, transfers). DORA, applying since 17 January 2025: a register of information on contracts with ICT third-party providers (Article 28(3)). The Czech cybersecurity act, No. 264/2025, in force from 1 November 2025, implementing NIS2. The EU AI Act	Which of these does this system touch, and who at CSOB is the first person we ask?
EU AI Act: risk class and dates	Regulation (EU) 2026/1744, the AI Omnibus, published 24 July 2026 and in force from 27 July 2026. It moves the stand-alone high-risk obligations (Annex III) to 2 December 2027 and the product-embedded ones (Annex I) to 2 August 2028. The prohibitions (from 2 February 2025) and most transparency duties (Article 50, from 2 August 2026) were not delayed, though some watermarking timings differ	Which class is this system provisionally in, what fact would change it, and who decides?
Personal data and residency	A record of processing. Processor contracts that say whether the provider may train on your data. A subprocessor list with locations. Data residency settings in managed cloud services	Where is it kept, for how long, in which country, and who can delete it? Does the trace hold a copy?
Cost as a safety signal	Spend limits and budget alerts in cloud billing. Token budgets and per-key limits at an LLM gateway. Iteration and turn caps in your own agent code (exhibit 1)	Is there a cap that stops the work, and an alert with a named reader? Who can stop it at 03:00?
Model choice and aliases	Pinned model identifiers: provider APIs and cloud catalogues use dated or versioned model IDs, and aliases can move. A re-test set run after any change	Are we on a pinned version or an alias? What re-runs when it moves?
Who runs which control	A control ownership matrix, owned and reviewed by a named function. The ISO/IEC 42001 AI management system standard and the NIST AI Risk Management Framework as frames for ownership and evidence	Who runs it, who would tell us if it stopped working, and what evidence would we ask for?
Traces and alerts	OpenTelemetry GenAI semantic conventions (moved to their own repository in June 2026, still marked Development, no official release yet). Observability tools such as Langfuse (open source, MIT core, owned by ClickHouse since January 2026), LangSmith (LangChain, proprietary) and Arize Phoenix (source-available, Elastic License 2.0; Arize is part of Dynatrace since 1 October 2026). An alert rule that can be run on last night's data (exhibit 3)	What is the first thing the person on call checks, and is it written down? Does every trace carry the configuration revision?
Guardrails	Amazon Bedrock Guardrails (works on models outside Bedrock through its ApplyGuardrail API), Prompt Shields within Microsoft Foundry guardrails (previously Azure AI Foundry), NVIDIA NeMo Guardrails (Apache 2.0), Meta's Llama Guard 4 (check its licence terms, which include an EU clause), Guardrails AI (open-source framework; the company was bought by Harvey in September 2026). Note that Protect AI archived LLM Guard on 9 July 2026, so it is no longer maintained. A labelled test set and a versioned settings file (exhibit 5)	What does it miss and what does it wrongly block? Who tunes it, and who notices if it stops working?
Automated red teaming and evaluation	garak (NVIDIA), PyRIT (Microsoft), promptfoo (OpenAI announced its acquisition on 9 March 2026), DeepTeam for attack runs. Inspect (UK AI Security Institute), DeepEval, Giskard for test suites. These give breadth and repeatability, not proof of safety	What was in scope, which model version, which languages, who judged, who owns the next run?
Security posture and governance	Commercial platforms for inventory, discovery of shadow AI and policy evidence. The category has consolidated: Palo Alto Networks bought Protect AI (completed July 2025), F5 bought CalypsoAI (closed 26 September 2025), Check Point bought Lakera (announced September 2025, now sold as Check Point AI Security), OpenAI announced Promptfoo (March 2026) and Harvey bought Guardrails AI (September 2026). Ask who owns the product now and what happens to the open-source version	What does it inventory that we cannot see today, and who acts on the finding?
Assurance reports	An independent review, a vendor attestation, a red-team summary: each is a claim until the evidence is shown	What would you check first by hand?

Frameworks and rules to name

- **OWASP Top 10 for LLM Applications (2026 edition)** and **OWASP Top 10 for Agentic Applications** (published 9 December 2025). "Excessive agency" is the OWASP name for what the tool sandbox limits.
- **Agents Rule of Two (Meta, 31 October 2025).** No more than two of: untrusted input, sensitive systems or private data, the power to change state or communicate outside. If it needs all three, a human approves.
- **DORA, Article 28(3).** A configuration record that names the model provider, the platform prompt owner and the tool servers is a natural input to the register of information.

Six questions for any vendor

1. What exactly did you test, against which version, and in which languages?
2. Who or what judged the result, and what did a person check by hand?
3. What did you not test, and how would we know?
4. How often is it re-run, and what triggers a re-run (a model, prompt or tool change)?
5. Who owns a finding, and what is the route into change control?
6. What does the contract say about our data, the subprocessors, and a change you make without telling us?

Sources

EU AI Act Omnibus, Regulation (EU) 2026/1744: K&L Gates (3 August 2026); Software Improvement Group (updated 14 August 2026). Garante decision: Lewis Silkin (14 January 2025). Samsung: Bloomberg via Business Standard (2 May 2023). Amazon Q Developer: AWS Insider (25 July 2025). Deloitte Australia: AP via CTV News (7 October 2025). Agent loop: Waxell, PolicyLayer (self-reported, not independently verified). Tool owners and statuses checked 4 November 2026: Check Point, F5 (SEC filing), OpenAI, Harvey and Dynatrace announcements; ClickHouse and Langfuse; Microsoft Learn; AWS What's New (June 2026); OpenTelemetry GenAI coverage (22 August 2026); LLM Guard archive notices.